今天想要讓架在 Fargate 的 nuclei 可以打到 ec2 的 metabase

要讓原本在 default VPC 的 nuclei 可以掃到建 EC2 時建的 VPC，可能需要先用 VPC peering。又因為 peering 只接通網路、SG 仍各自把關（ssh_sg 只開 22），所以還需要用 SG to SG 的方式讓 ssh_sg 放行，nuclei 才連得到 Metabase。

後來發現也可以把 nuclei 換到跟 ec2 同一個 vpc 就不用 VPC peering 了，接下來是實作的部分

SG-to-SG

就是一般的 SG 但是他的 inbound 填的是另一條 SG_id，所以不管是哪個 ip，只要掛著這個 SG 都可以連進來
好像還有看到一種用法，可以分層掛 SG，比如 web sg 連 app sg、app sg 連 db sg，就能乾淨地擋掉不該碰到 db 的流量

nuclei

原本 nuclei 在建立的時候會直接抓 default VPC 來套用（`filter = "is-default"`），現在改成先看有沒有 metabase，有的話就用 EC2 那邊的 VPC

```
if honeypot_vpcs.ids
    用 honeypot 的 vps
else
    default VPC
```

還有 SG 原本是拿 default 現在也要改成拿 nuclei_sg，至於為甚麼要讓 nuclei_sg 建在 ec2 那邊，因為如果建在 nuclei 這邊的話，build nuclei 的時候會來 nuclei 這邊找 nuclei_sg 但是這時候 nuclei 還沒建，因為要等 ec2 建好才有 vpc 可以用，之後改成兩邊各一個 vpc 就沒有這種為了避免循環依賴出現的奇怪的東西了..

```
if honeypot_vpcs
    去 metabase 找 nuclei_sg
else
    default_sg
```

```
→ pulumi up
Previewing update (prod):
     Type                 Name                Plan       Info
     pulumi:pulumi:Stack  5tmate-nuclei-prod
 ~   ├─ aws:lambda:Function    starter          update     [diff: ~code,environment,lastModified]
 +-  └─ aws:lambda:Permission  url-invoke       replace    [diff: ~principal]

Resources:
    ~ 1 to update
    +-1 to replace
    2 changes. 15 unchanged

Do you want to perform this update? yes
Updating (prod):
     Type                 Name                Status              Info
     pulumi:pulumi:Stack  5tmate-nuclei-prod
 ~   ├─ aws:lambda:Function    starter          updated (16s)       [diff: ~code,environment,lastModified]
 +-  └─ aws:lambda:Permission  url-invoke       replaced (0.56s)    [diff: ~principal]

Outputs:
    cluster_arn        : "arn:aws:ecs:ap-northeast-1:227469555418:cluster/nuclei"
    ecr_repo_url       : "227469555418.dkr.ecr.ap-northeast-1.amazonaws.com/nuclei"
    function_url       : "https://66ieswmgz3lnq2ej5nofnd4gp40djyhy.lambda-url.ap-northeast-1.on.aws/"
    task_definition_arn: "arn:aws:ecs:ap-northeast-1:227469555418:task-definition/nuclei:3"

Resources:
    ~ 1 updated
    +-1 replaced
    2 changes. 15 unchanged

Duration: 25s
```

metabase EC2

這邊要幫 nuciel 建好 nuclei_sg，允許所有向外的流量，不允許所有向內的流量

```
nuclei_sg = aws.ec2.SecurityGroup(
    "nuclei-sg",
```

```
    vpc_id=vpc.id,
    description="for nuclei task",
    egress=[
        {
            "description": "all outbound (scan target + nuclei templates)",
            "protocol": "-1",
            "from_port": 0,
            "to_port": 0,
            "cidr_blocks": ["0.0.0.0/0"],
        }
    ],
    tags={**tags, "Name": "5tmate-nuclei-sg"},
)
```

接著要設定 Sg to Sg，我想在原本 ec2 的 ingress 上面加一條，允許nuclei_sg 從 3000 進來

```
{
    "description": "Metabase from nuclei SG",
    "protocol": "tcp",
    "from_port": 3000,
    "to_port": 3000,
    "security_groups": [nuclei_sg.id],
        },
```

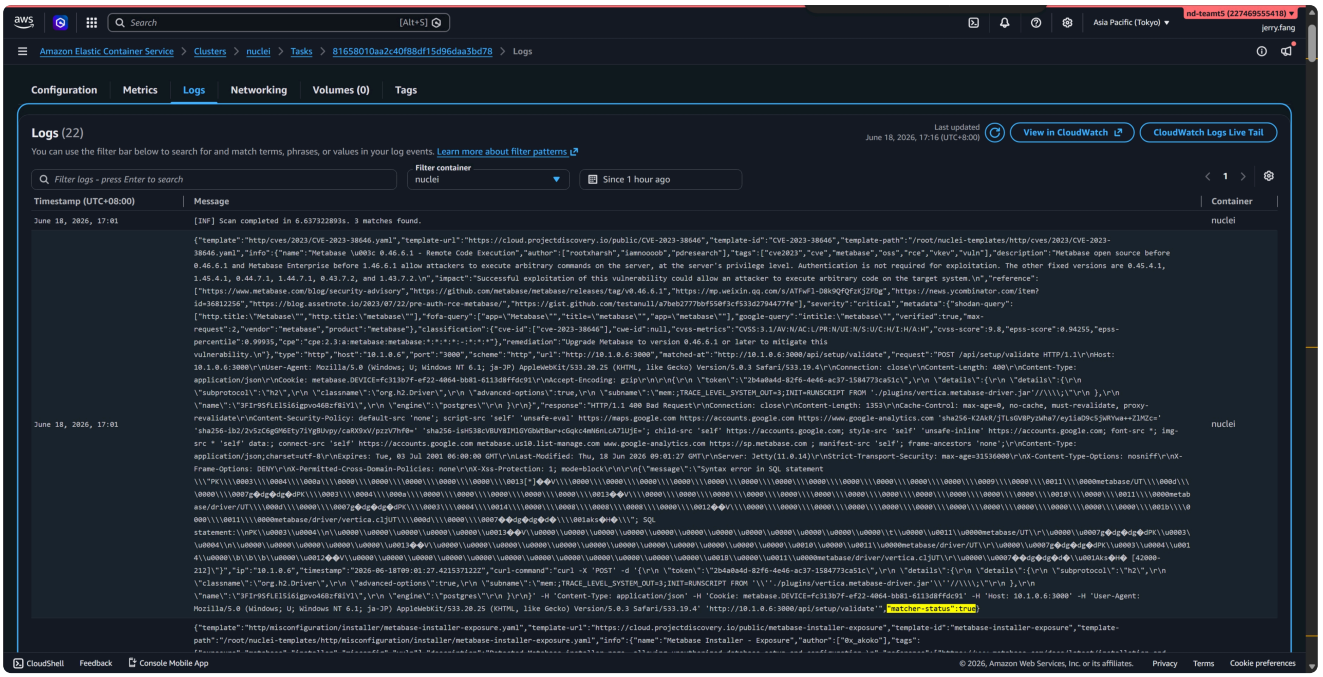
```
Do you want to perform this update? yes
Updating (prod):
     Type                              Name                  Status
 +   pulumi:pulumi:Stack               5tmate-metabase-prod  created (39s)
 +   ├─ aws:ec2:Vpc                    vpc                   created (12s)
 +   ├─ aws:iam:Role                   ssm-role              created (2s)
 +   ├─ aws:ec2:KeyPair                key                   created (1s)
 +   ├─ aws:iam:InstanceProfile        instance-profile      created (7s)
 +   ├─ aws:iam:RolePolicyAttachment   ssm-core              created (1s)
 +   ├─ aws:ec2:Subnet                 subnet                created (11s)
 +   ├─ aws:ec2:SecurityGroup          nuclei-sg             created (3s)
 +   ├─ aws:ec2:InternetGateway        igw                   created (1s)
 +   ├─ aws:ec2:RouteTable             rt                    created (1s)
 +   ├─ aws:ec2:SecurityGroup          ssh-sg                created (3s)
 +   ├─ aws:ec2:Instance               honeypot              created (13s)
 +   └─ aws:ec2:RouteTableAssociation  rt-assoc              created (1s)

Outputs:
    igw_id           : "igw-05a207486241c118f"
    instance_id      : "i-0cd3adc00034022be"
    nuclei_sg_id     : "sg-001be9a52364bb684"
    public_dns       : "ec2-18-179-37-223.ap-northeast-1.compute.amazonaws.com"
    public_ip        : "18.179.37.223"
    route_table_id   : "rtb-017cdd57e11730957"
    security_group_id: "sg-099b778c788059858"
    subnet_id        : "subnet-08087c6c79e4e9e94"
    vpc_id           : "vpc-041f052f1ee4c7481"

Resources:
    + 13 created

Duration: 43s
```

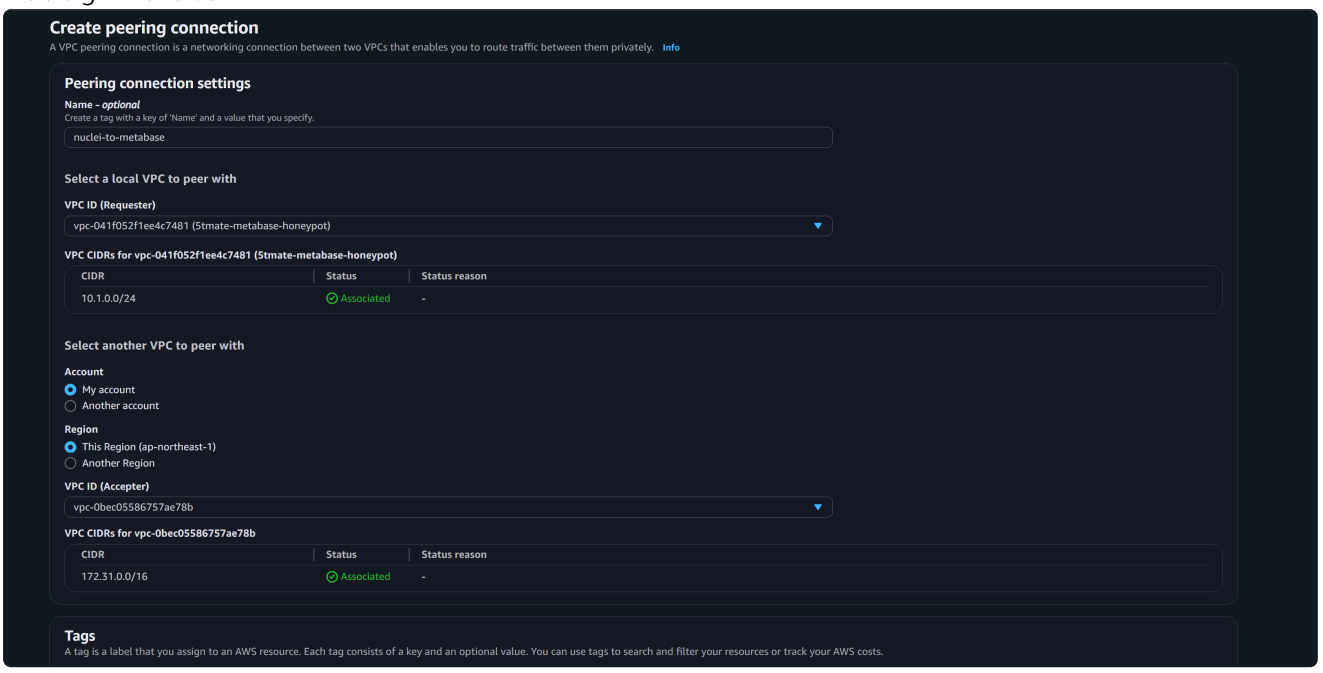
最後掃描結果確實顯示有中

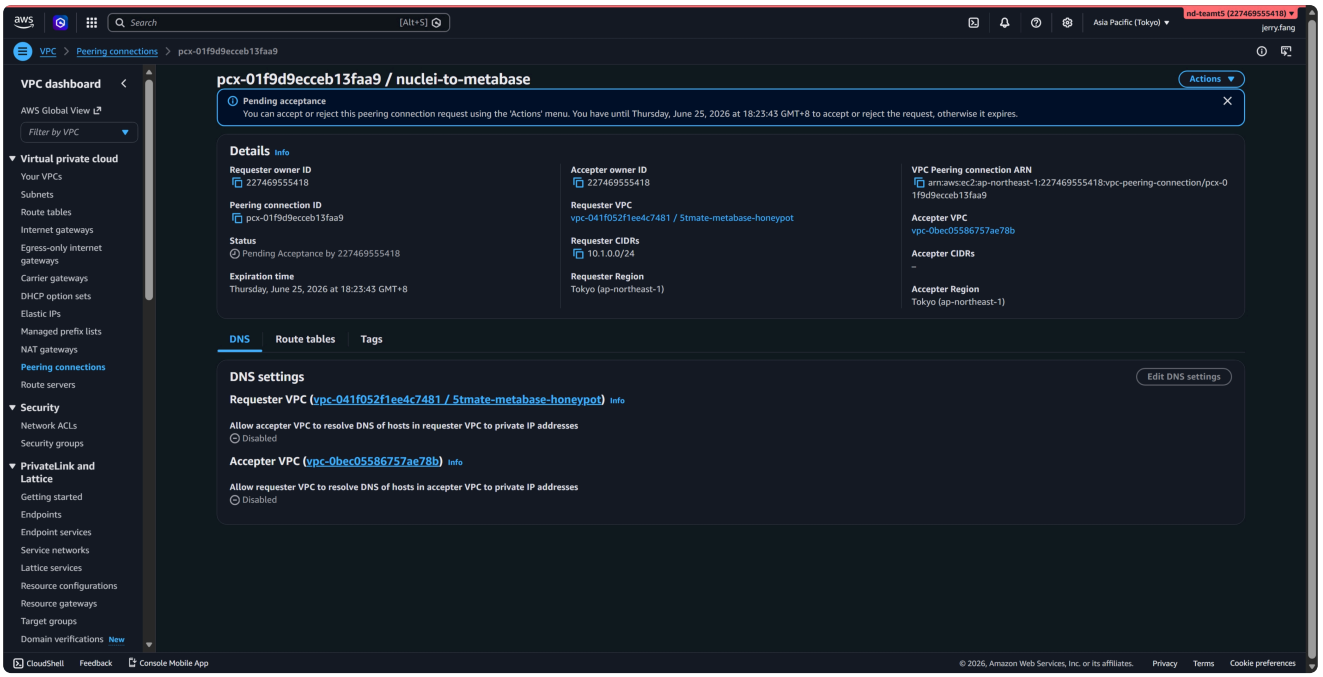


vpc peering

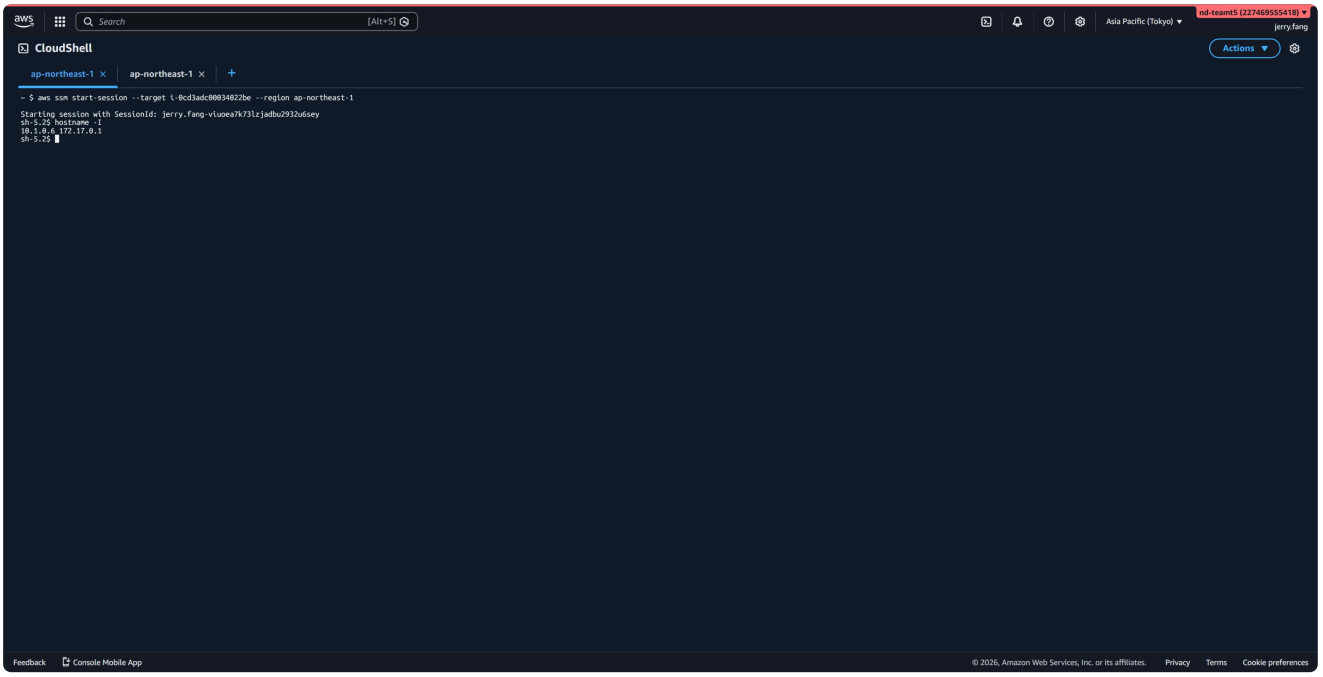
需要用到它就是在兩個同 region 的 vpc 需要互聯的時候，我想試試看

直接用 gui 建超快的





然後先進 ec2



現在應該只有 peer 連上但是 route 沒有設定好

小結

今天的目標是讓 nuclei 打得到 EC2 上的 Metabase。研究後有兩條路，一是不同 VPC 之間用 VPC peering 打通、再靠 SG to SG 放行，二是直接把 nuclei 放進跟 EC2 同一個 VPC，就不必 peering。先用同 VPC 加 SG to SG 的做法把 nuclei_sg 放行到 Metabase 的 3000 port，掃描確實命中。另外也順手試了 VPC peering，用 GUI 建很快，但目前只有 peer 連上、route 還沒設好，下次補上兩邊的路由再驗證。

參考資料

- Security groups（含以 SG 為來源的規則）
- What is VPC peering?
- Configure route tables - Amazon VPC